

OLAY MÜDAHALESİNİN TEMELLERİ

[Kaynak](#)

İÇERİK

1. Olay Müdahalesine Giriş (Introduction to Incident Response)
2. Olaylar Nedir? (What are Incidents?)
3. Siber Güvenlik Olayı Tipolojileri (Types of Security Incidents)
4. Olay Müdahale Süreçleri ve Metodolojik Çerçeveler (Incident Response Frameworks)
5. Olay Müdahale Teknikleri (Incident Response Techniques)

Olay Müdahalesine Giriş (Introduction to Incident Response)

Güvenliği zayıf bir çevrede, içerisinde yüksek değerli varlıklar barındıran bir sistemin mimarı olduğumuzu düşünelim. Fiziksel dünyada bu varlıkları korumak için güvenlik görevlileri ve kapalı devre kamera sistemleri (CCTV) konumlandırmak ne kadar elzemse, dijital dünyada da ağımızın sınırlarını korumak için benzer mekanizmalara ihtiyaç duyarız. Ayrıca, bir saldırganın dış güvenlik katmanlarını aşması (bypass) ihtimaline karşı, en değerli verileri gizli ve izole edilmiş bir "yeraltı kasasında" saklamak mantıklı bir stratejidir. Bu durum, siber güvenlikte **Proactive Defense** (Proaktif Savunma) ve **Defense in Depth** (Derinlemesine Savunma - savunmanın tek bir noktaya değil, katmanlara yayılması) kavramlarının temelini oluşturur. Bu önlemler, henüz hiçbir saldırı gerçekleşmeden önce sistemin dayanıklılığını artırmak için tasarlanır.

Ancak siber güvenlikte sadece saldırıyı önlemeye odaklanmak büyük bir stratejik hatadır. Sektörde kabul gören temel gerçek şudur: *Sistemler eninde sonunda ihlal edilecektir*. Bir tehdit aktörü dış güvenlik mekanizmalarınızı (Firewall, IPS/IDS vb.) başarılı bir şekilde aşip iç ağınıza (Internal Network) sızdığında, bu duruma nasıl tepki vereceğiniz, organizasyonun hayatta kalıp kalamayacağını belirler. İşte bu noktada, sistemin ihlal edilmesinden sonra devreye giren reaktif stratejiler ve operasyonel prosedürler başlar.

Siber Güvenlik Olayı (Cyber Security Incident) ve Olay Müdahalesi (Incident Response)

Organizasyonların binlerce, bazen milyonlarca dolar kaybetmesine yol açan ve internet üzerinde her gün raporlanan başarılı sızma veya yıkıcı saldırı eylemlerine **Cyber Security Incident** (Siber Güvenlik Olayı) adı verilir. Tıpkı fiziksel bir evin güvenliğinin önceden planlanması ve ihlal anında uygulanacak acil durum senaryolarının belirlenmesi gerektiği gibi, siber güvenlik olayları da devasa veri ve finansal kayıpları önlemek için ciddi bir planlama ve kaynak tahsisi gerektirir.

ÖNEMLİ: Incident Response (Olay Müdahalesi), bir siber güvenlik ihlalini başlangıcından (tespit) sonuna (kurtarma ve iyileştirme) kadar yöneten kapsamlı bir metodolojidir.

Bu süreç basitçe bir zararlı yazılımı silmekten ibaret değildir; çok daha geniş bir yelpazeyi kapsar:

- Olayların yaşanmasını engellemek veya tespit yüzeyini genişletmek için çeşitli ağ ve uç nokta (endpoint) bölgelerine güvenlik sensörleri yerleştirmek.
- Aktif olarak devam eden bir saldırı ile mücadele etmek (Containment - tehdidi izole etme).
- Saldırının organizasyon üzerindeki finansal, operasyonel ve itibar bazlı etkisini (impact) minimize etmek.

Kısacası, **Incident Response**, kaosu sistematik bir şekilde kontrol altına alma ve saldırganı ağdan tamamen kazıyıp (Eradication) sistemleri güvenli bir şekilde normal işleyişine döndürme kılavuzudur. Bu modül, olay müdahalesinin ardındaki bu kritik felsefeyi kavramamızı ve ilk canlı siber olayımızı pratik bir şekilde analiz edip çözmemizi sağlayacak temel yapı taşlarını sunmaktadır.

Olaylar Nedir? (What are Incidents?)

Bilgisayarlar, sunucular veya mobil cihazlar gibi tüm bilgi işlem sistemlerinde işletim sistemi seviyesinde sayısız süreç (process) çalışır. Bu süreçler genel olarak ikiye ayrılır: Kullanıcının doğrudan etkileşime girdiği interaktif süreçler (örneğin bir tarayıcı çalıştırmak) ve arka planda sistemin bütünlüğü ve işleyişi için çalışan, etkileşimsiz (non-interactive) servisler/daemon'lar. Teknik analiz açısından kritik olan nokta şudur: Bu süreçlerin gerçekleştirdiği her bir eylem, işletim sistemi veya uygulama seviyesinde bir **Event** (Sistem üzerinde gerçekleşen tekil aktivite veya durum değişikliği) üretir.

Sistemlerdeki bu muazzam sayıdaki süreçler, rutin olarak devasa hacimlerde log (kayıt) verisi üretir. İşletim sistemindeki veya ağdaki yıkıcı/zararlı bir aktivite, bu devasa log okyanusunun içinde sadece birkaç satırlık anomali olarak gizleniyor olabilir. Bir siber güvenlik analistinin bu ham logları manuel olarak incelemesi imkansızdır. Bu veri yığını anlamlı hale getirmek ve zararlı aktiviteleri tespit etmek için loglar, merkezi güvenlik çözümlerine (genellikle SIEM - Security Information and Event Management sistemlerine) aktarılır (Log Ingestion). Çözüm, tanımlı korelasyon kuralları (correlation rules) ve tehdit istihbaratı (threat intelligence) kullanarak bu logları işler.

Uyarı (Alert) Mekanizması ve Analiz Süreci

Güvenlik çözümü (SIEM, EDR, IDS vb.), sisteme akan **Event**'ler içinde potansiyel olarak zararlı bir aktivite örüntüsü veya imzası (signature) tespit ettiğinde bir **Alert** (Uyarı) tetikler. Olay müdahalesinin (Incident Response) asıl teknik ve analitik zorluğu, işte bu uyarının ekrana düşmesiyle başlar. Analistin görevi, bu uyarının sistemsal bir yanılğı mı yoksa gerçek bir tehdit mi olduğunu kanıtlamaktır.

Analiz sonucunda uyarılar iki temel teknik kategoriye ayrılır:

1. False Positive (Yanlış Pozitif): Güvenlik sisteminin bir eylemi zararlı olarak algılayıp uyarı ürettiği, ancak yapılan derinlemesine incelemede eylemin tamamen meşru ve zararsız olduğunun anlaşıldığı durumlardır. Bu durum, kuralların çok geniş (loose) yazılmasından veya sistemin normal davranış profilinin dışına çıkan anlık meşru işlemlerden kaynaklanabilir.

Örnek Senaryo: Güvenlik duvarı (Firewall) veya DLP (Data Loss Prevention) sistemi, bir iç sistemden harici bir IP adresine (External IP) doğru anormal derecede yüksek veri transferi tespit eder ve "Potansiyel Veri Sızdırma (Data Exfiltration)" uyarısı üretir. Ancak analistin incelemesi sonucunda, hedef sistemin o an yetkili bir bulut depolama servisine periyodik yedekleme (backup) işlemini gerçekleştirdiği anlaşılır. Uyarı zararsızdır, alarm **False Positive** olarak kapatılır.

2. True Positive (Doğru Pozitif): Güvenlik çözümünün zararlı olarak işaretlediği aktivitenin, analistin incelemesi sonucunda gerçekten de sistemi tehlikeye atan, saldırgan kaynaklı meşru bir tehdit olduğunun kanıtlanmasıdır.

Örnek Senaryo: Ağ geçidindeki e-posta güvenlik çözümü, bir kullanıcıya gelen e-postada **Phishing** (Oltalama - kullanıcıyı kandırarak zararlı bir bağlantıya tıkatmaya, kimlik bilgilerini girmeye veya zararlı bir dosyayı indirmeye zorlayan sosyal mühendislik vektörü) emaresi tespit eder. Analist e-postanın header (başlık) bilgilerini, gönderen IP'nin itibarını (reputation) ve içerikteki bağlantıyı izole bir ortamda (sandbox) analiz ettiğinde, bunun sistemi ele geçirmek amacıyla gönderilmiş gerçek bir saldırı olduğunu doğrular. Alarm **True Positive** olarak işaretlenir.

Siber Güvenlik Olayı (Incident) ve Önceliklendirme (Severity/Triage)

ÖNEMLİ: Sektörel terminolojide, analist tarafından doğrulanmış olan ve organizasyona zarar verme potansiyeli taşıyan bir **True Positive** uyarısı, artık bir **Incident** (Siber Güvenlik Olayı) olarak sınıflandırılır. Bir uyarının olaya dönüşmesi, resmi Olay Müdahalesi (Incident Response) prosedürlerinin başlatılması anlamına gelir.

Gerçek dünya senaryolarında, bir SOC (Security Operations Center) ekibinin önüne aynı anda birden fazla **Incident** düşebilir. Güvenlik ekiplerinin kısıtlı zaman ve kaynağı olduğu için, rastgele müdahale etmek yerine sistematik bir yaklaşım izlenmelidir. Bu noktada **Incident Severity** (Olay Şiddeti/Kritiklik Seviyesi) devreye girer.

Severity değerlendirmesi (Triage süreci), olayın organizasyon üzerindeki potansiyel etkisine (operasyonel kesinti, veri sızıntısı, finansal kayıp) ve tehdidin ağ içinde yayılma (lateral movement) kapasitesine göre yapılır. Olaylar genellikle şu şekilde kategorize edilir:

- **Low (Düşük):** Etkisi sınırlı, izole edilmiş tehditler (örn. antivirüs tarafından engellenmiş ve silinmiş izole bir zararlı yazılım).

- **Medium (Orta):** Belirli bir kullanıcıyı veya sistemi etkileyen, yayılma riski düşük olaylar.
- **High (Yüksek):** Kritik sistemleri etkileme potansiyeli olan veya veri sızıntısı şüphesi taşıyan olaylar.
- **Critical (Kritik):** Doğrudan Domain Controller gibi çekirdek sistemleri hedef alan, aktif olarak devam eden Ransomware (Fidye Yazılımı) enfeksiyonları veya geniş çaplı veri hırsızlığı gibi tüm operasyonu durdurabilecek olaylar.

Her zaman için en yüksek öncelik **Critical** seviyesindeki olaylara verilir ve kaynaklar sırasıyla aşağıya doğru (High, Medium, Low) tahsis edilir



Siber Güvenlik Olayı Tipolojileri (Types of Security Incidents)

Halk arasında dijital dünyadaki her türlü zararlı aktivite yüzeysel bir yaklaşımla "hacklenme" olarak etiketlense de, profesyonel siber güvenlik operasyonlarında olaylar (incidents) çok spesifik metodolojilere ve etki alanlarına göre kategorize edilir. Bir hedefin ağında bu olay tiplerinden yalnızca biri bağımsız olarak görülebileceği gibi, karmaşık bir saldırı vektöründe (örneğin bir APT grubu tarafından) hepsi eşzamanlı bir zincir halinde de karşımıza çıkabilir.

Temel olay tipolojilerini ve operasyonel mantıklarını şu şekilde özetleyebiliriz:

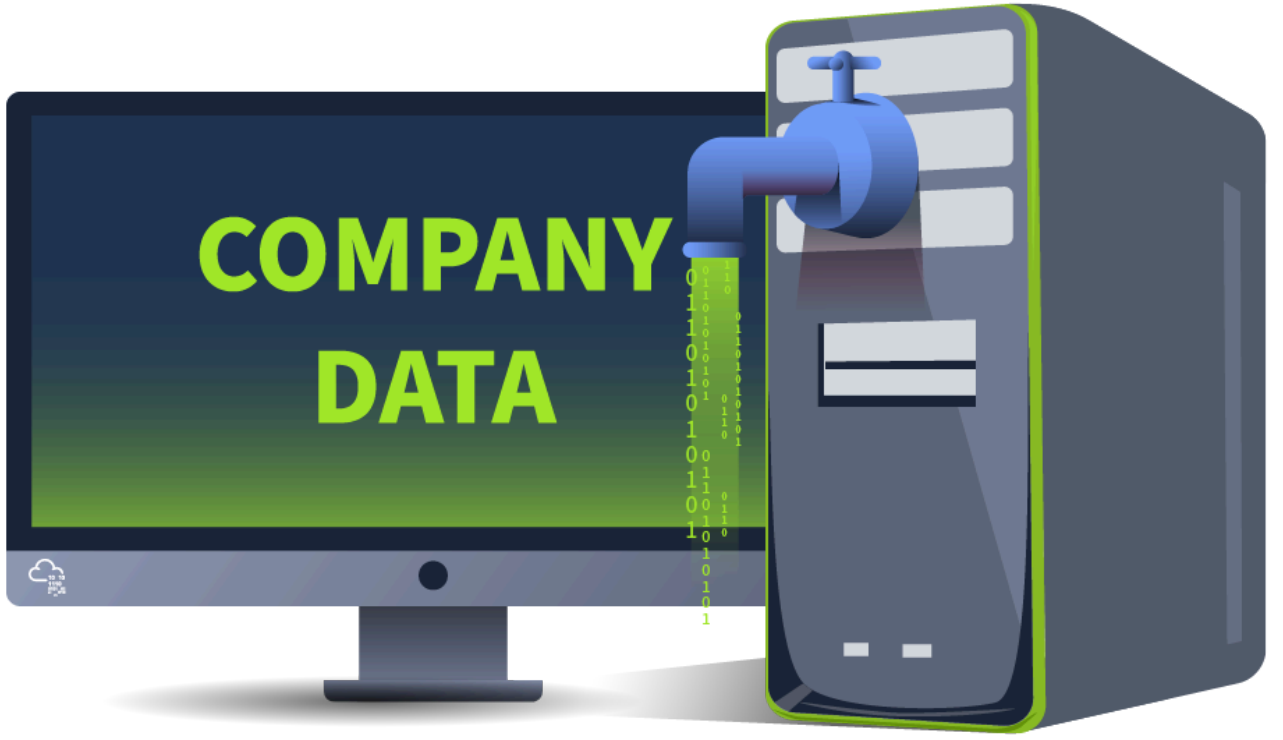
Malware Infections (Zararlı Yazılım Enfeksiyonları): Olay müdahale süreçlerinin (Incident Response) en sık karşılaştığı durumdur. Sistemlere, ağ altyapısına veya spesifik uygulamalara zarar vermek (veya kontrolü ele geçirmek) amacıyla derlenmiş kod parçacıklarıdır. Genellikle son kullanıcıya ulaştırılan dokümanlar, metin dosyaları veya çalıştırılabilir (executable) dosyalar aracılığıyla sistemde çalıştırılarak (execution) başlatılırlar.



Security Breaches (Güvenlik İhlalleri) ve **Data Leaks** (Veri Sızıntıları): Bu iki kavram sıkça birbirine karıştırılsa da teknik doğaları farklıdır. **Security Breaches**, yetkisiz bir tehdit aktörünün organizasyonun gizli verilerine doğrudan erişim yetkisi kazanması eylemidir; gizliliğin (Confidentiality) doğrudan ihlalidir.



Data Leaks ise bu gizli verilerin organizasyon dışındaki yetkisiz entitelere ifşa olması durumudur. Tehdit aktörleri sızdırılan verileri genellikle şantaj veya itibar zedeleme amacıyla bir silah olarak kullanır. Ancak Data Leaks her zaman bir siber saldırı sonucu olmak zorunda değildir; yetkili personelin insan hatası veya bulut sistemlerindeki bir yanlış yapılandırma (misconfiguration) sonucunda da kazara oluşabilir.



Insider Attacks (İç Tehdit Saldırıları): Güvenlik çevresinin (perimeter) dışından gelen tehditlerin aksine, doğrudan organizasyonun iç ağında (Internal Network) bulunan ve zaten sistemlere belirli bir seviyede erişim yetkisi olan kişiler tarafından gerçekleştirilen saldırılardır. İşten ayrılmadan hemen önce şirketin kritik verilerini çalan veya ağa zararlı bir USB takan memnuniyetsiz bir çalışan klasik bir Insider örneğidir. İçerideki bir kullanıcının Firewall veya IPS gibi dış savunma mekanizmalarını zaten aşmış (veya arkasında) olması nedeniyle, bu saldırıların tespit edilmesi son derece zordur ve yaratacağı hasar potansiyeli çok daha yüksektir.



Denial of Service Attacks (Servis Dışı Bırakma Saldırıları - **DoS**): Bilgi güvenliğinin temel direklerinden olan erişilebilirliği (Availability) hedef alan mimari bir saldırı türüdür. Herhangi bir veriyi korumak, eğer o veriye meşru kullanıcılar erişemiyorsa anlamsızdır. **DoS** saldırılarında tehdit aktörü; hedef sunucuyu, ağı veya web uygulamasını sahte isteklerle (false requests) boğar. Sistem, gelen bu devasa boyuttaki sahte trafiği işlemek için CPU, RAM veya bant genişliği gibi kaynaklarını tüketir (Resource Exhaustion) ve sonuç olarak meşru kullanıcılara (legitimate users) hizmet veremez hale gelerek çöker.



ÖNEMLİ: Olayların kritiklik seviyesi (Severity) ve hedefe vereceği zarar evrensel bir doğru değildir; tamamen kurban organizasyonun iş modeline ve altyapısına bağlıdır. Örneğin, elinde kritik veya satılabilir bir fikri mülkiyet (Intellectual Property) bulunmayan bir şirket için **Data Leak** düşük riskli bir olay olarak değerlendirilebilir. Ancak tüm operasyonunu ve gelir modelini ana web sitesi üzerinden yürüten aynı şirket için başarılı bir **DoS** saldırısı, telafisi imkansız finansal kayıplara yol açan kritik bir felaket anlamına gelecektir.

Olay Müdahale Süreçleri ve Metodolojik Çerçeveler (Incident Response Frameworks)

Siber güvenlik operasyonlarında farklı tipteki karmaşık saldırıları doğaçlama yöntemlerle yönetmek, organizasyonları geri dönülmez operasyonel ve finansal felaketlere sürükler. Bir siber kriz anında, teknik ekiplerin (SOC/CIRT) panik veya belirsizlik yaşamadan, saat gibi işleyen bir prosedürü takip etmesi şarttır. İşte bu noktada **Incident Response Frameworks** (Olay Müdahale Çerçeveleri) devreye girer. Bu çerçeveler, olayın anatomisini parçalara bölerek her bir aşamada ne yapılması gerektiğini, hangi aracın kullanılacağını ve yasal/teknik sınırların ne olduğunu belirleyen evrensel kılavuzlardır.

Sektörde küresel standartları belirleyen iki ana otorite **SANS** (SysAdmin, Audit, Network and Security) ve **NIST** (National Institute of Standards and Technology) kurumlarıdır. İki kurumun

olay müdahale mantığı felsefi olarak aynı temel amaca (zararı durdur, sistemi kurtar, ders çıkar) hizmet etse de, operasyonel adımların sınıflandırılmasında kritik mimari farklılıklar gösterirler.

SANS Olay Müdahale Çerçevesi (PICERL Metodolojisi)

SANS çerçevesi, analistin olay anındaki odaklanmasını maksimize etmek için süreci **6 belirgin faza** ayırır. Sektörde bu süreç, akılda kalıcılığı artırmak için **PICERL** (Preparation, Identification, Containment, Eradication, Recovery, Lessons Learned) akronimi ile anılır.

1. Preparation (Hazırlık): Olay müdahalesinin en kritik, ancak genellikle en çok ihmal edilen aşamasıdır. Kriz anında "Şimdi ne yapacağız?" sorusunu sormamak için barış zamanında yapılan tüm mimari ve idari yapılandırmaları kapsar.

- **Arka Plan Mantığı:** Gerekli log kaynaklarının (Firewall, EDR, Windows Event Logs) merkezi bir SIEM'e entegre edilmesi, olay müdahale ekibinin (CIRT) yetki sınırlarının belirlenmesi ve son kullanıcıların **Phishing** (Oltalama) gibi saldırı vektörlerine karşı eğitilmesi bu fazdadır. Eğer hazırlık aşamasında ağ görünürlüğünüz (Network Visibility) yoksa, bir sonraki aşama olan tespit fazında tamamen kör olursunuz.

2. Identification (Tespit ve Analiz): Sistemdeki anormal bir davranışın (Anomaly) veya bir güvenlik uyarısının (Alert) gerçekten bir ihlal olup olmadığının doğrulandığı aşamadır.

- **Teknik Derinlik:** Güvenlik ekipleri, ağdan dışarıya doğru (Egress traffic) gerçekleşen anormal veri transferlerini analiz eder. Örneğin, bir kullanıcının oltalama e-postasındaki zararlı eki indirmesi sonucu bir uç noktanın (Endpoint) ele geçirilmesi (Compromise) bu aşamada tespit edilir. Hedef, zararlıının **Root Cause**'unu (Kök Neden) ve etkilediği sistemlerin tam listesini (Scope) belirlemektir.

3. Containment (Sınırlandırma): DİKKAT: Olay tespit edildiğinde içgüdüsel olarak zararlıyı hemen silmek istenir, ancak bu *büyük bir hatadır*. Sınırlandırma aşamasının amacı zararlıyı silmek değil, kanamayı durdurmak ve saldırganın ağ içinde **Lateral Movement** (Yatay Hareket - diğer sunuculara sıçrama) yapmasını engellemektir.

- **Operasyonel Adımlar:** İhlal edilen makinenin (Victim machine) ağ kablosu çekilmez (çünkü RAM'deki uçucu deliller silinir), bunun yerine EDR (Endpoint Detection and Response) üzerinden ağ izolasyonuna alınır (Network Isolation). Ele geçirilen kullanıcı hesaplarının (Compromised accounts) Active Directory üzerinden anında devre dışı bırakılması (Disable) bu fazın standart prosedürüdür.

4. Eradication (Yok Etme / Temizleme): Sınırlandırma başarıyla sağlandıktan ve deliller toplandıktan sonra, tehdidin sistemden kalıcı olarak kazındığı aşamadır.

- **Nasıl Yapılır?:** Zararlı yazılımların derinlemesine taramalarla (Deep malware scan) silinmesi, saldırganın sisteme bıraktığı arka kapıların (Backdoor) veya kalıcılık mekanizmalarının (Persistence - örn: Zamanlanmış görevler veya Registry kayıtları)

temizlenmesi ve zafiyete neden olan açıklıkların (Vulnerabilities) yamalanması (Patching) bu aşamada gerçekleşir.

5. Recovery (Kurtarma ve Normale Dönüş): Temizlenen ortamın tekrar iş operasyonlarına dahil edildiği aşamadır.

- **Risk ve Önlem:** Etkilenen sistemler temiz yedeklerden (Backup) geri yüklenir veya **Golden Image** (Sistemin en güvenli, taze imajı) kullanılarak sıfırdan kurulur (Rebuilding). *Eğer bu adımda acele edilirse ve Eradication aşamasında bir arka kapı unutulmuşsa, sistem ağa bağlandığı an tekrar ihlal edilir.* Bu nedenle kurtarılan sistemler bir süre sıkı gözetim (Hyper-care) altında tutulur.

6. Lessons Learned (Çıkarılan Dersler / Post-Incident Review): Kriz sona erdikten sonra tüm paydaşların masaya oturduğu, olayın anatomisinin tartışıldığı evredir.

- **Neden Önemlidir?:** "Saldırgan içeri nasıl girdi?", "Neden daha erken tespit edemedik?", "Hangi logları alamadık?" gibi sorular sorularak mevcut güvenlik mimarisi güncellenir. Bu aşamada tespit edilen boşluklar (Gaps) kapatılarak sürecin Preparation (Hazırlık) aşamasına geri besleme (Feedback loop) sağlanır.

NIST Çerçevesi ve SANS ile Yapısal Karşılaştırması

NIST standartları (NIST SP 800-61), SANS'ın 6 aşamalı yapısını **4 ana faza** indirgeyerek daha döngüsel (cyclical) bir yaklaşım benimser:

SANS	NIST
Preparation	Preparation
Identification	Detection and Analysis
Containment	Containment, Eradication, and Recovery
Eradication	
Recovery	
Lessons Learned	Post Incident Activity

1. **Preparation** (Hazırlık)
2. **Detection & Analysis** (Tespit ve Analiz - SANS'taki Identification)

3. **Containment, Eradication, and Recovery** (Sınırlandırma, Yok Etme ve Kurtarma)

4. **Post-Incident Activity** (Olay Sonrası Aktivite - SANS'taki Lessons Learned)



ÖNEMLİ: NIST'in Sınırlandırma, Yok Etme ve Kurtarma adımlarını tek bir çatı altında toplamasının teknik bir mantığı vardır. Gerçek dünya senaryolarında (örneğin bir APT grubuyla savaşıırken) bu üç adım genellikle doğrusal işlemez; sistemleri kurtardıkça yeni zararlılar tespit edebilir ve tekrar sınırlandırma fazına dönmek zorunda kalabilirsiniz. NIST bu üçlüyü birbiriyle iç içe geçmiş bir **döngü** olarak kabul eder.

Incident Response Plan (Olay Müdahale Planı)

SANS veya NIST çerçevelerinin kağıt üzerinde kalmaması için, organizasyonların üst yönetimi (C-Level) tarafından resmi olarak onaylanmış bir **Incident Response Plan (IRP)** belgesine sahip olması zorunludur. Bu belge, kriz anının anayasasıdır.

Bir Master-Class Incident Response Planı şu hayati bileşenleri barındırır:

- **Roles and Responsibilities (Roller ve Sorumluluklar):** Kriz anında kimin sunucuları kapatma yetkisi var? Kriz iletişimini kim yönetecek? Bu durumlar RACI (Responsible, Accountable, Consulted, Informed) matrisleriyle kesin olarak belirlenir.
- **Incident Response Methodology:** Olay anında SANS mı yoksa NIST mi takip edilecek? Hangi tür olaylara (Ransomware, Insider Threat vb.) hangi Playbook'lar (Özel müdahale senaryoları) uygulanacak?
- **Communication Plan (İletişim Planı):** Olayın boyutuna göre kolluk kuvvetlerine (Law Enforcement), yasal regülatörlere (KVKK, GDPR yetkilileri) ve basına ne zaman ve nasıl bilgi verileceğinin protokolüdür. Yanlış bir iletişim, organizasyonun hisse değerini siber saldırıdan daha fazla düşürebilir.
- **Escalation Path (Eskalasyon/Tırmandırma Yolu):** Seviye 1 (Tier 1) bir analist, incelediği olayın kritik (Critical) seviyede bir fidye yazılımı (Ransomware) olduğunu anladığında, teknik ve idari yöneticilere hangi kanallardan (Telefon, Out-of-band mesajlaşma vb.) ulaşacağını yol haritasıdır. Çökmüş bir e-posta sunucusundan atılan bir "Acil" e-postası, eskalasyon yolunun çalışmadığının en acı kanıtıdır.

Olay Müdahale Teknikleri (Incident Response Techniques)

Siber güvenlik operasyonlarında bir ihlali tespit etmek kadar, bu ihlale nasıl müdahale edileceğini yapısal bir düzende bilmek de kritiktir. Manuel yöntemlerle anormal davranışları

(abnormal behavior) tespit etmek, günümüzün karmaşık ağ yapılarında imkansıza yakındır. Bu nedenle, **Incident Response (IR - Olay Müdahale)** süreci belirli standartlara ve teknolojik çözümlere dayandırılmalıdır.

Olay Müdahale Yaşam Döngüsü ve Fazlar

Endüstri standartları olan **SANS** ve **NIST**, olay müdahale süreçlerini farklı terminolojilerle ancak benzer mantıkla ele alır. **SANS** çerçevesinde ikinci aşama olan **Identification** (Tanımlama/Tespit), **NIST** standartlarında **Detection and Analysis** (Tespit ve Analiz) olarak adlandırılır. Bu fazın temel amacı; sistemdeki anomalinin gerçekten bir güvenlik olayı (security incident) olup olmadığını doğrulamak ve olayın kapsamını belirlemektir.

Güvenlik Çözümleri ve Teknolojik Katmanlar

Olayların tespit edilmesi, analiz edilmesi ve hatta bazı durumlarda otomatik olarak durdurulması için merkezi ve uç nokta tabanlı çözümler kullanılır:

- **SIEM (Security Information and Event Management):** Ağ genelindeki tüm kritik logları (kayıtları) merkezi bir konumda toplar. En hayati fonksiyonu **Correlation** (Korelasyon - İlişkilendirme) yeteneğidir. Farklı kaynaklardan gelen (Firewall, IDS/IPS, OS Logları) verileri birleştirerek, tek başına anlam ifade etmeyen olaylar silsilesinden bir saldırı paterni çıkarır.
- **AV (Antivirus):** Sisteme sızmaya çalışan **Known Malicious** (Bilinen Kötü Amaçlı) programları tespit etmek için imza tabanlı (signature-based) tarama yapar. Reaktif bir savunma hattıdır; halihazırda tanımlanmış tehditleri durdurmada başarılıdır.
- **EDR (Endpoint Detection and Response):** Her bir uç noktaya (sunucu, iş istasyonu vb.) konuşlandırılır. **AV**'den temel farkı, sadece dosya taraması yapmamasıdır. Süreçleri, ağ bağlantılarını ve kullanıcı davranışlarını izleyerek gelişmiş tehditleri (**Advanced Threats**) tespit eder. Ayrıca, tehdidi izole etme (**Containment**) ve temizleme (**Eradication**) kabiliyetine sahiptir.



Müdahale Stratejileri: Playbook ve Runbook Ayrımı

Bir olay tespit edildikten sonra, müdahalenin hızı ve doğruluğu zararı minimize eder. Bu süreçte iki temel rehber doküman kullanılır:

1. **Playbook (Olay Müdahale Planı):** Kapsamlı bir olay müdahalesi için genel stratejik yönergeleri içerir. "Bir ortalama saldırısı olduğunda genel olarak ne yapılmalı?" sorusunun yanıtıdır. Yüksek seviyeli bir yol haritası sunar.
2. **Runbook (Uygulama Kitabı):** **Playbook** içindeki spesifik adımların nasıl icra edileceğini gösteren, düşük seviyeli ve ayrıntılı teknik talimatlardır. Kullanılan araçlara ve mevcut kaynaklara göre değişkenlik gösterir. Örneğin; "E-posta başlığını (header) analiz etmek için X aracıyla Y parametresi kullanılmalıdır" gibi adım adım talimatlar içerir.

Örnek Vaka Analizi: Phishing (Ortalama) Playbook Akışı

Bir **Phishing** vakası tespit edildiğinde izlenmesi gereken mantıksal silsile şu şekilde olmalıdır:

1. **Paydaşların Bilgilendirilmesi:** İlgili tüm departmanlar ve teknik ekipler durumdan haberdar edilir.
2. **E-posta Analizi:** Gönderilen iletinin **Header** (Üstbilgi) ve **Body** (Gövde) analizi yapılır. Gönderen adresi, **SMTP** sunucusu, **SPF/DKIM/DMARC** kayıtları kontrol edilerek iletinin sahteliği doğrulanır.
3. **Eklerin İncelenmesi:** E-posta ile gelen ekler (Attachment) varsa, bunlar güvenli bir **Sandbox** (Kum havuzu) ortamında analiz edilir. Zararlı yazılım barındırıp barındırmadığı

netleştirilir.

4. **Etki Analizi:** Organizasyon içinde herhangi bir kullanıcının bu ekleri açıp açmadığı veya içindeki linklere tıklayıp tıklamadığı (Click-through rate) loglar üzerinden kontrol edilir.
5. **İzolasyon (Containment):** Enfekte olduğu tespit edilen sistemler, saldırının ağ içinde yayılmasını (**Lateral Movement**) engellemek amacıyla derhal ağdan izole edilir.
6. **Bloklama:** Saldırganın e-posta adresi veya alan adı (Domain) **Blacklist** (Kara Liste) listesine alınarak gelecekteki benzer saldırıların önüne geçilir.

DİKKAT: Playbook'lar stratejiyi belirlerken, bu adımların teknik olarak nasıl yapılacağı (örneğin; SIEM üzerinde hangi sorgunun çalıştırılacağı veya firewall üzerinden hangi kuralın yazılacağı) **Runbook**'ların konusudur. Başarılı bir **Incident Response** operasyonu, bu iki dokümanın uyumuyla mümkündür.